

Manual 27 — Implementación Controlada de Gobernanza de Datos e Ingeniería de Privacidad

Traducción de proyecto es-419 — no oficial

****Orden de la serie:**** 27

****Base publicada de NIST:**** NIST Privacy Framework 1.0

****Vigilancia de cambios:**** borrador público inicial de NIST Privacy Framework 1.1 / versión final futura

****Referencia de ingeniería de privacidad:**** NISTIR 8062

****Límite:**** Este manual es guía de implementación, no asesoría jurídica, aprobación regulatoria, certificación ni sustituto de la legislación aplicable por jurisdicción.

01. Propósito, alcance y límites

Defina prácticas empresariales de gobernanza de datos e ingeniería de privacidad sin confundir orientación con obligaciones jurídicas específicas de una jurisdicción.

02. Jerarquía de fuentes y control de cambios

Separe leyes/regulaciones, orientación de reguladores, NIST Privacy Framework, orientación de ingeniería de privacidad, contratos, políticas y estándares internos.

03. Modelo operativo de gobernanza de datos

Defina consejos, stewards, custodios, propietarios, privacidad, seguridad, legal, registros, arquitectura y roles de responsabilidad del negocio.

04. Inventario y linaje de datos

Mantenga inventarios autoritativos de dominios de datos, sistemas, flujos, almacenes, encargados/procesadores, transferencias y relaciones de linaje.

05. Clasificación y manejo

Establezca criterios de clasificación, reglas de manejo, condiciones de acceso, límites de intercambio, requisitos de protección y evidencia.

06. Especificación de propósito y limitación de uso

Registre propósitos empresariales aprobados, usos compatibles, restricciones, responsables, disparadores de revisión y excepciones.

07. Minimización de datos

Recopile, cree, conserve y exponga únicamente datos proporcionales a los propósitos y obligaciones definidos.

08. Calidad y exactitud de datos

Defina dimensiones de calidad, validación, corrección, propiedad, monitoreo y controles de gestión de problemas.

09. Retención y eliminación

Implemente calendarios de retención, retenciones legales, eliminación, archivo, disposición, excepciones y evidencia de ejecución.

10. Gobernanza de acceso

Aplique mínimo privilegio, controles basados en roles/atributos, acceso privilegiado, revisión periódica, segregación y revocación.

11. Intercambio y divulgación de datos

Controle el intercambio interno y externo mediante autorización, acuerdos, restricciones de propósito, minimización, registro y revisión.

12. Flujos transfronterizos y jurisdiccionales de datos

Mantenga evaluaciones jurídicas/contractuales de transferencia y evite asumir que un único mecanismo global aplica en todas partes.

13. Evaluación de riesgos de privacidad

Identifique daños a la privacidad, personas afectadas, probabilidad, severidad, mitigaciones, riesgo residual y disparadores de reevaluación.

14. Objetivos de ingeniería de privacidad

Traduzca objetivos de privacidad en propiedades del sistema como predictibilidad, gestionabilidad, disociabilidad, control y transparencia.

15. Privacidad desde el diseño y por defecto

Incorpore requisitos de privacidad en arquitectura, SDLC, adquisiciones, gestión de cambios y configuraciones predeterminadas.

16. Gestión de consentimiento y preferencias

Cuando corresponda, gobierne avisos, opciones, estado del consentimiento, retiro, propagación de preferencias, evidencia y excepciones.

17. Operaciones de derechos individuales

Soporte acceso, corrección, eliminación, portabilidad, oposición, restricción y otros derechos aplicables mediante flujos de trabajo conscientes de la jurisdicción.

18. Protección de identidad y datos sensibles

Aplique gobernanza reforzada para identificadores, credenciales, datos de salud, financieros, biométricos, ubicación precisa, datos de menores y datos similares cuando corresponda.

19. Desidentificación y seudonimización

Defina técnicas aprobadas, evaluación del riesgo de reidentificación, controles, pruebas, contratos y restricciones de uso.

20. Tecnologías de mejora de la privacidad

Evalúe cifrado, tokenización, computación segura, privacidad diferencial, técnicas federadas, datos sintéticos y otras PET de forma proporcional al riesgo.

21. Registro, monitoreo y observabilidad

Registre accesos, intercambio, eliminación, estado de consentimiento, solicitudes de derechos, excepciones de política y cambios materiales en flujos de datos.

22. Gobernanza de datos de terceros

Evalúe encargados/proveedores, instrucciones, subprocesamiento, evidencia, controles de seguridad/privacidad, retención, eliminación y obligaciones ante incidentes.

23. Gobernanza de nube y plataformas de datos

Gobierne data lakes, warehouses, SaaS, plataformas analíticas, object stores, APIs, notebooks e intercambio entre cuentas.

24. Analítica y uso secundario

Revise nuevas analíticas, enriquecimiento, inferencias, perfilado y reutilización respecto de compatibilidad de propósito, riesgo de privacidad, equidad y transparencia.

25. Arquitectura de registros y evidencia

Mantenga decisiones, evaluaciones, aprobaciones, mapeos, excepciones, avisos, contratos, logs, registros de problemas y evidencia de remediación.

26. Coordinación de incidentes y brechas

Integre la gobernanza de datos con detección, contención, evaluación, notificación, recuperación y lecciones aprendidas de incidentes de seguridad/privacidad.

27. Métricas e indicadores

Rastree cobertura de inventario, calidad de datos, desempeño de derechos, ejecución de retención, revisión de acceso, riesgo de privacidad, problemas de proveedores y antigüedad de remediación.

28. Capacitación y competencia por rol

Proporcione capacitación basada en roles para propietarios, stewards, ingenieros, analistas, privacidad, seguridad, adquisiciones y liderazgo.

29. Aseguramiento y pruebas

Pruebe el diseño y la operación de la gobernanza mediante muestreo, validación de controles, pruebas técnicas, revisión de solicitudes de derechos e inspección de evidencia.

30. Revisión de gestión

Revise desempeño, cambio regulatorio, incidentes, riesgo de privacidad, métricas, excepciones, recursos y prioridades de mejora.

31. Mejora continua

Use hallazgos, incidentes, quejas, resultados de auditoría, cambios tecnológicos y regulatorios para impulsar mejoras controladas.

32. Publicación y hoja de ruta de implementación

Empaquete rutas de implementación Esencial / Estructurada / Mejorada con verificación de fuentes, localización, accesibilidad, procedencia, checksums, seguridad de workflows, evidencia de revisión humana cuando se requiera y controles de publicación secuencial.